

Hobbeast — Üzleti kérés összefoglaló

Verzió: 1.7.4 Dátum: 2026-09-05

Security

Focused P0 hardening pass from the fresh 5-sprint audit

(Hobbeast_friss_repoaudit_es_hatralevo_5_sprintes_fejlesztési_terv_v2.md). Only the concrete, decision-free code fixes were shipped in this round — the deeper multi-Supabase-project contract, SECURITY DEFINER SQL audit, dependency upgrades, CI quality gate, and full domain refactors are deferred and require per-sprint execution with rotation runbooks and characterization tests.

Removed the hardcoded Mapy API key fallback from src/lib/mapy.ts. Action required: rotate the previously-committed Mapy key in the Mapy console and set VITE_MAPY_API_KEY — see docs/SECRETS_ROTATION.md. src/pages/Auth.tsx now sanitizes the ?redirect= query parameter: only relative, single-slash, internal paths are honored. Blocks //host, protocol-relative, javascript:, backslash and any absolute URL — closes the open-redirect vector. Google OAuth redirectTo no longer points at the hardcoded hobbeast.vercel.app origin; it now uses window.location.origin, so sign-in returns to whichever domain the user actually authenticated from (localhost, Lovable preview, expericentre.com, custom domains).

Fixed

Duplicate OAuth error toast branch in src/pages/Auth.tsx collapsed to a single, correct handler.

src/pages/EventDetail.tsx external-event sessionStorage load is now wrapped in try/catch; a corrupted payload no longer throws at render, and the bad entry is cleared. src/pages/EventDetail.tsx "Szervezés" button no longer navigates to the undeclared /events/:id/organize route; it now opens /organizer?event=:id, which the existing /organizer route handles.

Changed

README.md "Current version" bumped 1.6.8 → 1.7.4 (the release validator only checks package.json vs CHANGELOG.md, so this string had drifted).

Deferred (documented, not shipped)

Sprint 1.1 (multi-Supabase project contract & single env source of truth), 1.4 (SECURITY DEFINER / Vault / admin RPC hardening migration), 1.5 (CI quality gate workflow), 2 (place-search / eventing domain rebuild), 3 (organizer & admin core split), 4 (community / notification / a11y), 5 (product & brand finalization deep pass) all require per-sprint owner decisions (rotation, allowlists, DB migration review) and characterization tests. Ship them one sprint per round.

Ez az összefoglaló 2026-09-05-én készült visszamenőleg, a CHANGELOG.md megfelelő bejegyzéséből származtatva, mert ehhez a verzióhoz eredetileg nem készült versioning-artefaktum. A tartalma a changeloból ellenőrizhető; nem a kiadás napján kelt dokumentum.